Security Review

2026-09-09 by SECBIT Labs

At the request of the AladdinDAO team, we conducted a security review of a change to the CLever smart contract.

The change can be found at: https://github.com/AladdinDAO/aladdin-v3-contracts/pull/278

Reviewed commit: `680b0c9b453a6c1232901d75cd49c3dc0592df6d`.

This report describes the change background, change details, change analysis, potential issues and security review results of the change.

PR#278: clever lock drift

Change Background

Historically, `processUnlockableCVX()` was not called on time in several epochs. As a result, certain global accounting variables in `CLeverCVXLocker` no longer matched the actual fund state. This change is intended to correct those accounting discrepancies.

Change Details

The change primarily modifies the internal logic of `processUnlockableCVX()`, which is called by the keeper, and adds a withdrawal from the CVX Reward Pool when the direct CVX balance is insufficient for relocking. It also comments out `initialize()` to reduce code size; this implementation is intended to upgrade an already initialized proxy.

Change Analysis

The change introduces corrective logic into `processUnlockableCVX()`.

1. Functionality and Intended Objectives

At the beginning of `processUnlockableCVX()`, the new `_fixLockDrift()` function applies an epoch-specific accounting adjustment before the normal unlocking process begins.

In Epoch 2957, the pending amount for Epoch 2957 is merged into the stale Epoch 2838 record so that it is not incorrectly processed in that epoch. In Epoch 2958, the contract moves the affected amounts into `pendingUnlocked[2958]`, adjusts `totalPendingUnlockGlobal`, refunds the 3,173 CVX previously advanced by the `owner`, and processes the corrected pending amount through the normal unlocking logic. Any CVX not assigned to users is relocked.

In Epochs 2970 and 2971, the contract removes the temporary surplus recorded in `totalUnlockedGlobal`. In Epoch 2972, it introduces another temporary pending amount to align the next lock cycle. The corresponding surplus is then removed in stages during Epochs 2973, 2974, and 2975.

After all specified calls through Epoch 2975 have completed successfully, `totalUnlockedGlobal` and `totalPendingUnlockGlobal` are restored to values consistent with the actual fund state.

2. Limitations and Governance Risks

The remediation is distributed across multiple epochs rather than completed in a single transaction. The upgrade and the Epoch 2957 call to `processUnlockableCVX()` must complete successfully in the same atomic Safe batch before September 10, 2026, at 00:00 UTC. The keeper must then execute the function every week through Epoch 2975, including weeks without an epoch-specific corrective branch.

If any required call is missed, the relevant branch in `_fixLockDrift()` cannot be executed later because it is selected by the current epoch. This may leave the accounting only partially corrected, cause later adjustments to operate on unexpected values, or make subsequent calls revert. Completing the remediation therefore requires timely keeper execution and active operational monitoring throughout the entire period.

Potential Issues Found

1. Repayment of 3,173 CVX May Fail in Epoch 2958

In Epoch 2958, the contract first repays the 3,173 CVX advanced by the `owner`. This transfer uses the CVX held directly by `CLeverCVXLocker` and does not first withdraw funds from the CVX Reward Pool.

At Ethereum mainnet block 25,938,303 (September 9, 2026, at 07:24:35 UTC), the contract held approximately 15,410.55 CVX directly. If a user calls `withdrawUnlocked()` before the Epoch 2958 remediation and reduces this balance below 3,173 CVX, the repayment to the `owner` will fail due to insufficient funds, reverting the entire `processUnlockableCVX()` transaction.

The authorized keeper should ensure that the contract holds sufficient CVX directly when executing `processUnlockableCVX()` in Epoch 2958. This issue can be considered resolved once that transaction has completed successfully.

2. Certain Historical `pendingUnlocked` Records Are Not Cleared

After the Epoch 2975 remediation is completed, `totalUnlockedGlobal` and `totalPendingUnlockGlobal` will be correct, but the following historical records will still retain their old values:

- `pendingUnlocked[2817]`
- `pendingUnlocked[2818]`
- `pendingUnlocked[2838]`

These values no longer have valid accounting meaning. We recommend clearing them in a subsequent update to prevent the stored historical state from being inconsistent with its intended semantics. In practice, these stale records do not affect the security of user funds.

3. Temporary Semantic Deviation in Global Accounting Variables

Between Epochs 2957 and 2975, `totalUnlockedGlobal` and `totalPendingUnlockGlobal` are used to carry historical accounting adjustments. Their values may therefore temporarily deviate from their intended meanings.

Specifically:

- `totalUnlockedGlobal` is intended to represent CVX that users have unlocked but not yet withdrawn;
- `totalPendingUnlockGlobal` is intended to represent CVX for which users have requested an unlock but that has not yet expired.

During the remediation period, `totalUnlockedGlobal` temporarily includes amounts reserved for subsequent accounting adjustments, in addition to CVX unlocked by users but not yet withdrawn. These temporary adjustments are expected to be fully unwound by the successful completion of the planned remediation in Epoch 2975.

Review Results

After reviewing the development team's upgrade and remediation plan and supporting validation results, and discussing our findings with the team, we consider it reasonable to proceed with merging the reviewed code. This assessment is conditional on strict adherence to the plan, including timely execution of all required epoch-specific operations, sufficient liquidity for the repayment, ongoing monitoring, and the agreed reward compensation. Provided these conditions are met, we expect the implementation costs and residual risks to remain within acceptable bounds.